

Assignment 4 Crafting a solution to a vulnerable network

Contents

Introduction	1
Task 1: IPTABLES Warmup Exercise	1
Task 1 Executive Summary	2
Task 2: A More Complex Situation.....	2
Task 2 Executive Summary	4
Task 3: Looking At The Bigger Picture.....	4
Task 3 Executive Summary	7

Introduction

This paper covers several important exercises in creating iptables rules to design a network security architecture. Task 1 is a simple iptables exercise, task 2 is a more complex iptables exercise, and task 3 is a holistic design exercise in setting up an entire network security architecture for hypothetical small company.

Task 1: IPTABLES Warmup Exercise

Listed below are the iptables rules / commands that I implemented to satisfy the following requirements. After I will explain line by line what each command does and how the rules work together to satisfy the requirements.

- allow incoming traffic on port 80 (HTTP) and port 443 (HTTPS)
- block all other incoming traffic
- allow outgoing traffic on port 53 (DNS) and port 123 (NTP)
- block all other outgoing traffic not generated in response to approved incoming traffic
- enable logging for dropped packets

1. `iptables --flush`
2. `iptables -A INPUT -p tcp --dport 80 -m conntrack --ctstate NEW,ESTABLISHED -j ACCEPT`
3. `iptables -A INPUT -p tcp --dport 443 -m conntrack --ctstate NEW,ESTABLISHED -j ACCEPT`
4. `iptables -A OUTPUT -m conntrack --ctstate ESTABLISHED,RELATED -j ACCEPT`
5. `iptables -A OUTPUT -p udp --dport 53 -m conntrack --ctstate NEW,ESTABLISHED -j ACCEPT`
6. `iptables -A OUTPUT -p udp --dport 123 -m conntrack --ctstate NEW,ESTABLISHED -j ACCEPT`
7. `iptables -A INPUT -j DROP`
8. `iptables -A OUTPUT -m conntrack --ctstate NEW -j DROP`
9. `iptables -A INPUT -j LOG --log-prefix "IPTables-Dropped: " --log-level 4`
10. `iptables -A OUTPUT -j LOG --log-prefix "IPTables-Dropped: " --log-level 4`

Rules Explanation: Rule 1 removes all existing rules. Rules 2 and 3 are to allow incoming traffic on ports 80 and 443. Rule 4 is meant to allow traffic for responses needed for HTTP and HTTPS requests. Rules 5 and 6 are to allow outgoing traffic on ports 53 and 123. Rule 7 drops all other incoming traffic. Rule 8 drops all other outgoing traffic. Rules 9 and 10 log all dropped incoming and outgoing traffic. The order of the rules is important to make sure that the designated traffic is allowed but all other traffic will be dropped. Rule 3 is specifically important to allow responses to HTTP and HTTPS traffic.

Task 1 Executive Summary

The basics of iptables rules are an important aspect of creating a suitable DMZ and network protection system. In general, it is much safer to whitelist or allow specific traffic for known services rather than just allowing all traffic. In this case having known specific traffic makes it easy to create iptables rules that would allow traffic and specifically protect against all other unknown traffic.

Task 2: A More Complex Situation

Task two is a more complex iptables rule exercise where I will be configuring iptables to achieve the following objectives.

- Allow all outgoing traffic from the firewall/router server and the internal network, but block all outgoing traffic from the DMZ network, except for DNS and NTP.
- Allow incoming traffic on port 80 (HTTP) and port 443 (HTTPS) from the internet to the web server in the DMZ network, but block all other incoming traffic to the DMZ network.
- Allow incoming traffic on port 21 (FTP) from the internet to the FTP server in the DMZ network, but only from a specific IP range (203.0.113.0/24).
- Allow incoming traffic on port 22 (SSH) from the internet to the firewall/router server, but only from a specific IP address (198.51.100.1).
- Allow incoming traffic on port 25 (SMTP) from the internet to the mail server in the internal network, but only if the source IP address is in a allowlist file (/etc/iptables/smtp_whitelist.txt).
- Block all other incoming traffic from the internet to the internal network.
- Enable logging for all dropped packets with a prefix "IPTables-Dropped: ".

1. iptables --flush
2. iptables -A INPUT -m conntrack --ctstate ESTABLISHED,RELATED -j ACCEPT
3. iptables -A FORWARD -m conntrack --ctstate ESTABLISHED,RELATED -j ACCEPT
4. iptables -A FORWARD -i eth1 -j ACCEPT
5. iptables -A FORWARD -i eth2 -p udp --dport 53 -j ACCEPT
6. iptables -A FORWARD -i eth2 -p udp --dport 123 -j ACCEPT
7. iptables -A FORWARD -i eth2 -j DROP
8. iptables -A FORWARD -p tcp -d 10.0.0.10 --dport 80 -m conntrack --ctstate NEW,ESTABLISHED -j ACCEPT
9. iptables -A FORWARD -p tcp -d 10.0.0.10 --dport 443 -m conntrack --ctstate NEW,ESTABLISHED -j ACCEPT
10. iptables -A FORWARD -p tcp -s 203.0.113.0/24 -d 10.0.0.20 --dport 21 -m conntrack --ctstate NEW,ESTABLISHED -j ACCEPT
11. iptables -A INPUT -p tcp -s 198.51.100.1 --dport 22 -m conntrack --ctstate NEW,ESTABLISHED -j ACCEPT
12. if [-f /etc/iptables/smtp_whitelist.txt]; then
13. while IFS= read -r ip; do
14. iptables -A FORWARD -p tcp -s "\$ip" -d 192.168.1.200 --dport 25 -m conntrack --ctstate NEW,ESTABLISHED -j ACCEPT
15. done < /etc/iptables/smtp_whitelist.txt

16. fi

17. iptables -A INPUT -j LOG --log-prefix "IPTables-Dropped: " --log-level 4

18. iptables -A FORWARD -j LOG --log-prefix "IPTables-Dropped: " --log-level 4

The above rules establish the requirements listed for task 2 by doing the following. Line or Rule 1 flushes all existing rules. Lines 2 and 3 allow established and related connections to still pass through. Line 4 allows outgoing traffic from the internal network (eth1). Line 5 and line 6 allow DNS and NTP traffic from the DMZ (eth2). Line 7 drops all other outgoing traffic from the DMZ (eth2). Lines 8 and 9 allow incoming HTTP and HTTPS traffic to the web server at 10.0.0.10 on ports 80(HTTP) and 443 (HTTPS). Line 10 allows incoming traffic FTP traffic over port 21 to the FTP server (10.0.0.20) from 203.0.113.0/24. Line 11 allows incoming SSH traffic over port 22 to the firewall from 198.51.100.1. Lines 12 through 16 allowing incoming SMTP traffic over port 25 to the mail server (192.168.1.200) from IPs in /etc/iptables/smtp_whitelist.txt. Lines 17 and 18 Log all dropped incoming or outgoing packets with prefix "IPTables-Dropped: ". The order of these rules is important for making sure that the correct traffic is allowed but all others are dropped and logged. Specifically, the internet network can send any traffic to the internet, the DMZ is restricted to DNS and NTP only all other outgoing is dropped. The web and FTP servers in the DMZ are accessible and internal services like SMTP are restricted to specific whitelisted IP addresses while all other unsolicited traffic to the internal network is blocked.

Task 2 Executive Summary

In this exercise I examined a more complex and realistic situation for implementing iptables rules. This situation included things like a mail server, FTP server, DNS, NTP, HTTP, and HTTPS traffic. These rules work together to create a more comprehensive network security solution that specifically manages traffic by whitelisting known safe traffic and dropping and logging all other traffic. By implementing a whitelist file this allows a network engineer to quickly and easily add known safe addresses for the SMTP service.

Task 3: Looking At The Bigger Picture

The company's online services include a web application which allows customers to create and manage their accounts, a database that stores the customers' data, and an email server that sends and receives messages. The web application, the database, and the email server are hosted on three separate servers in the LAN. The web application server is accessible from the internet through port 80 (HTTP) and port 443 (HTTPS). The database server and the email server are only accessible from the LAN or the VPN.

The company faces various security threats from the internet, such as denial-of-service (DoS) attacks, web application attacks, phishing emails, malware infections, and data breaches. The company wants to protect its network and its online services from these threats by using a firewall, an IDS, and an IPS.

- Allow legitimate traffic from the internet to the web application server on port 80 and 443, but block all other traffic from the internet to the LAN.
- Allow legitimate traffic from the VPN to the LAN, but block any traffic from the VPN that tries to access unauthorized services or ports in the LAN.
- Allow legitimate traffic from the LAN to the internet, but block any traffic from the LAN that tries to access malicious or suspicious websites or services on the internet.
- Detect any anomalous or malicious traffic in the network using signatures, heuristics, or machine learning techniques.
- Prevent any detected attacks from reaching their targets by dropping or modifying the malicious packets.
- Log any detected or prevented attacks and generate alerts for further investigation.

To protect this businesses network I will describe a network security architecture that includes things like the firewall, IDS, and IPS systems. The network itself consists of a LAN, firewall/router, VPN, web application server, database server, and an email server. All these devices will be described further to specify their role / location in the greater network security architecture. The basic goals that need to be accomplished are:

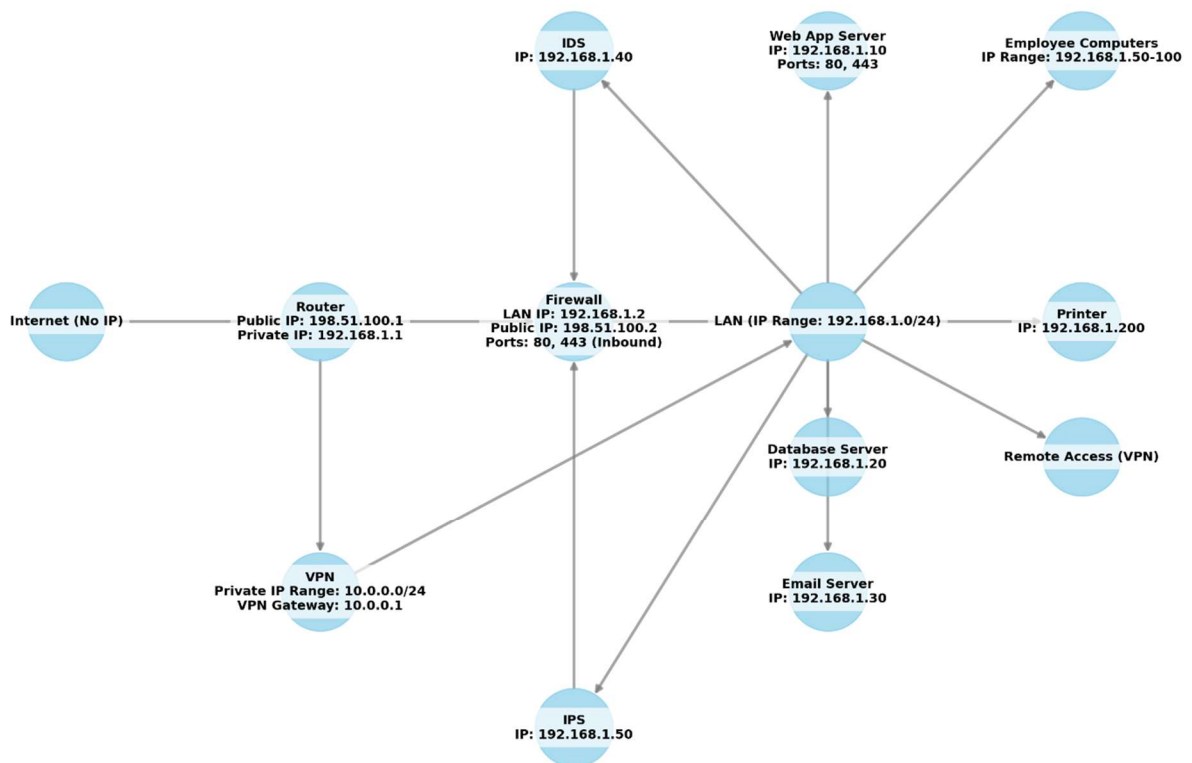
1. Allow legitimate traffic from the internet to the web application server on port 80 and 443, while blocking all other traffic from the internet to the LAN.
2. Allow legitimate traffic from the VPN to the LAN, while blocking unauthorized access to services and ports.
3. Allow legitimate traffic from the LAN to the internet, while blocking access to malicious websites and services.
4. Detect anomalous and malicious traffic using signature-based, heuristic, and machine-learning techniques.
5. Prevent detected attacks by dropping or modifying malicious packets.

6. Log all detected and blocked attacks and generate alerts for investigation.

The first part of the network architecture is the firewall component. The firewall will be configured to allow incoming traffic on ports 80 and 443 to the web application server to allow it connection to the internet. The firewall will also be configured to allow traffic from the VPN to the LAN for accessing the database and email servers, however the VPN connection will be required for connecting to these devices. The firewall will be configured to use DNS filtering to block malicious sites. Lastly the fire wall will enforce outgoing traffic control to prevent data from being extracted from the network.

The next major component in the security architecture is the intrusion detection system or IDS. The IDS monitors traffic for suspicious patterns and anomalies. It will use signature-based and anomaly-based recognition techniques. The log that detects threats will send alerts to any admin / owners of the network for further investigation and containment.

Another major component is the intrusions prevention system or IPS. The IPS sits in line with network traffic to intercept incoming and outgoing traffic. The IPS will drop and modify packets to accomplish the above listed goals such as. Allowing traffic between the web application server and the internet. The IPS will also have rules to manage the VPN traffic to ensure legitimate traffic from the VPN to the LAN, but block any traffic from the VPN that tries to access unauthorized services or ports in the LAN and Allow legitimate traffic from the LAN to the internet, but block any traffic from the LAN that tries to access malicious or suspicious websites or services on the internet. Additionally, the IPS system can be used to log any note worthy packets that are dropped and send alerts to the network admins/ owners. Below is a basic network diagram showing the connections between various components and some real some hypothetical addresses of the devices.



This design will create a layered defense of overlapping rules and abilities from the firewall, IDS, and IPS. The combination of all these components should create a network security architecture that protects the entire network and all devices on it. A major part of the design is to minimize the attack surfaces by making only necessary services and ports accessible. The network security architecture has comprehensive threat detection by using both a passive IDS and IPS system for monitoring and active prevention. This network security architecture ensures that the small business network is protected from external threats while providing secure access to internal services. The combination of firewall, IDS, and IPS delivers a robust security framework, enhancing network resilience and data protection.

Task 3 Executive Summary

This network security architecture provides a layered and comprehensive security framework. The architecture that I have described accomplishes the security objectives described above by doing the following. Minimizing attack surfaces by restricting access to

services and ports using rules configured in the network IPS, IDS, and firewall. These various rules will restrict network access to only necessary services such as the web application server and the VPN. There will also be strong logging and alerting rules to notify network administrators of note worthy packets that are dropped or similar intrusions into the network. This combination of devices and rules should provide a secure network posture for the described business environment.